

Phase 2: Security+, Linux, and Offensive Foundations

Security+ Lesson 2

AAA, Non-Repudiation, Gap Analysis, and Zero Trust

Yesterday learned: Security Controls, Threat, Vulnerability, Risk, Likelihood, Impact, and Residual Risk

AAA stands for: Authentication, Authorization, and Accounting

Authentication

> Who are you?

Alice enters domain credentials. Kerberos/domain authentication establishes her identity.

Authorization

> What are you allowed to do?

Alice: \\SRV-DC01\HR -> allowed but \\SRV-DC01\Finance denied

Accounting

> What did the identity actually do?

Accounting is about tracking activity associated with identities/resources.

(Alice logs in -> 4624) These records help provide accountability.

Non-repudiation: Imagine Kevin digitally approves an important transaction. Later: "I never approved that." Security mechanisms may provide evidence making it difficult for the actor to credibly deny performing the action. That's **non-repudiation**. This can be connected to: digital signatures, logging, identity, integrity, and accountability.

Gap analysis: You have: Desired secure state vs Current actual state. The difference is the **gap**. Remember:

Desired: Minimum Password Length = 12, Actual: Minimum Password Length = 7

The gap is now identified. Then: Assess -> prioritize -> remediate -> verify.

Zero Trust: Traditional bad assumption: "You're inside the corporate network, therefore I trust you." Zero Trust says location alone should not automatically equal trust. A useful phrase is: **Never automatically trust; continually verify based on policy and context**. Imagine Alice is already inside Bear Corp. Zero Trust doesn't say: Internal IP -> Alice gets everything. Instead, the environment may consider: Identity, Device, Privilege, Resource, Risk, Authentication strength, Context, Policy before granting access.

Linux Lesson 2

Privileges, Groups, Permissions, and sudo

Yesterday: whoami, id, ls -l, rwx, 754, ps, ip addr, ip route

Root: Linux has a highly privileged administrative identity: root. Root does not equal /. / is the root directory. Root is the privileged user account

UID: Linux identities have numeric IDs. Command: **id**

UID -> user, GID -> group

Root account has: UID 0.

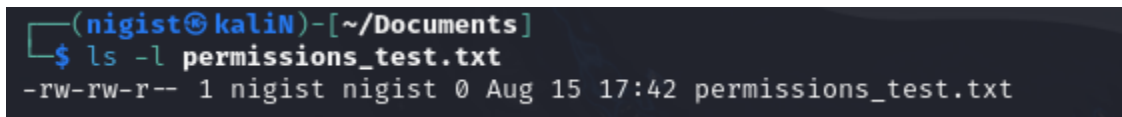
Sudo: allows authorized users to execute commands with elevated privileges according to configuration. Ex: sudo <command>

Sudo -l shows what the current user is allowed to execute through sudo.

Permissions Practice

Creating a harmless file. Command: **touch permission_test.txt**

View it: **ls -l permission_test.txt**



```
(nigist@kaliN)-[~/Documents]
$ ls -l permissions_test.txt
-rw-rw-r-- 1 nigist nigist 0 Aug 15 17:42 permissions_test.txt
```

Rw- | rw- | r-

Owner: Read and Write, Groups: Read and Write, Others: Read

Command: **chmod 754 permissions_test.txt**.....only changes Owner's permissions to Read, Write, and Execute

Process Privilege Context

Command: **ps aux**

Looking at the USER column, many different processes execute under different identities.

Offensive Security Lesson 2

Nmap Beyond "Port Open"

Port States: Nmap doesn't only say: open. I need to understand several states.

1. Open: A service is accepting connections.
2. Closed: The host responded, but nothing is listening on that port.
 - a. Useful: suggests the host exists and is reachable, but this service isn't available
3. Filtered: Nmap cannot determine whether the port is open because something is interfering with the probes.
 - a. Often: Firewall, Filtering device, Packet filtering

Default Scan vs Targeted Scan

Yesterday: nmap <IP> gave a basic look at common ports. But assessors frequently need to ask: Am I scanning the ports I actually care about?

I can target specific ports: nmap -p 445 <IP> or a set: nmap -p 53,88,389,445 <IP>

All TCP ports

A basic Nmap scan doesn't necessarily examine every possible TCP port.

There are: 1-65535 TCP port numbers. An all-port scan can be requested with **nmap -p- <IP>**.

What did the default scan show versus what else exists when I inspect the complete TCP range?

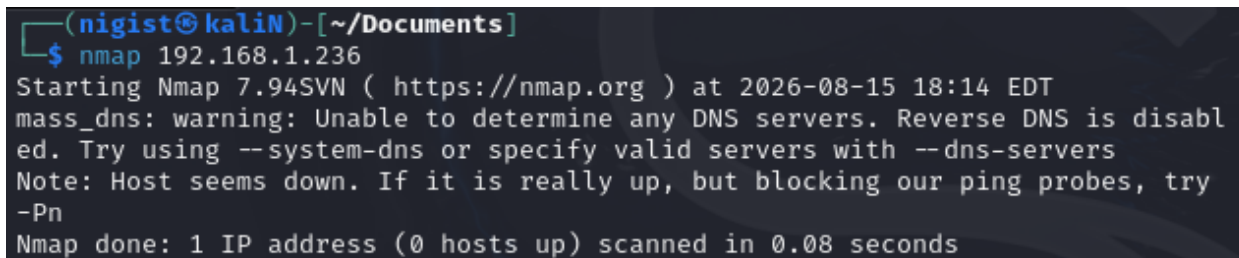
Service Detection

Command: **nmap -sV <IP>**

Nmap sees: 445/tcp open then sends additional probes and analyzes responses to determine the running service. This is known as service enumeration. Eventually: Port -> Service -> Product/version/configuration -> Potential weakness research.

Practical: Build a proper SRV-DC01 service picture

Nmap <SRV-DC01 IP>



```
(nigist@kali)-[~/Documents]
$ nmap 192.168.1.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-15 18:14 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 0.08 seconds
```

Neither the client, nor domain controller (Windows Server) is working today. I'm going to edit the firewall for the client to allow ICMP echo requests. Just easier to turn it off for now.

So the problem wasn't the server nor client, it was the Kali Linux VM. It had eth0 down. I had to run **sudo dhclient -v eth0**. (needs explanation)

Now retrying..**nmap <SRV-DC01 IP>** still gives the same as the screenshot from above. When adding -Pn, it gives:

```

(nigist@kaliN)-[~]
$ nmap -Pn 192.168.1.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-15 18:38 EDT
Nmap scan report for 192.168.1.236
Host is up (0.0010s latency).
Not shown: 989 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
389/tcp    open  ldap
445/tcp    open  microsoft-ds
464/tcp    open  kpasswd5
593/tcp    open  http-rpc-epmap
636/tcp    open  ldapssl
3268/tcp   open  globalcatLDAP
3269/tcp   open  globalcatLDAPssl

Nmap done: 1 IP address (1 host up) scanned in 4.75 seconds

```

Added Service Version Detection:

```

(nigist@kaliN)-[~]
$ nmap -Pn -sV 192.168.1.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-15 18:40 EDT
Nmap scan report for 192.168.1.236
Host is up (0.00098s latency).
Not shown: 989 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-08-15 22:40:16Z)
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp    open  ldap             Microsoft Windows Active Directory LDAP (Domain: kevinlab.local,
Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds?
464/tcp    open  kpasswd5?
593/tcp    open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped
3268/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: kevinlab.local,
Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
Service Info: Host: SRV-DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.89 seconds

```

Full TCP ports scan

```
(nigist@kali)~$ nmap -Pn -p- 192.168.1.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-15 18:41 EDT
Nmap scan report for 192.168.1.236
Host is up (0.0011s latency).
Not shown: 65515 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
9389/tcp  open  adws
49664/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
64372/tcp open  unknown
64373/tcp open  unknown
64383/tcp open  unknown
64390/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 103.86 seconds
```

Clean up Loose Ends

Didn't understand the dhclient command I used to troubleshoot (since I had AI do the fix, time to understand it)

Command: **sudo dhclient -v eth0**

Breakdown:

- Sudo gives elevated privileges to execute the command
- Dhclient is DHCP client: communicates with DHCP infrastructure and tries to obtain network configuration
- -v (verbose): show more detail about what the DHCP client is doing
- Eth0: interface i wanted configured

Also, next time when dealing with enabling ICMP Echo Requests....I won't disable the entire firewall. That's how I learned in university, so I just did that. But I can just allow the ICMP Echo Request specifically after some research.

Understand What Yesterday's Scan Actually Found

Port 53: DNS

Why would a Domain Controller expose DNS? Well, in the lab SRV-DC01 is also the DNS server. Domain clients need DNS to discover: Domain Controllers, Kerberos, LDAP, Global Catalog, or other AD services.

So finding DNS from Kali tells an assessor: This host may be doing more than simply Windows file sharing. It may participate in infrastructure or service discovery.

Port 88: Kerberos

Kerberos provides domain authentication. From project 1, we know that: User -> Kerberos authentication -> TGT -> Service ticket -> Resource Access

An assessor finding 88/tcp open exposes LDAP and DNS has strong architectural clues that this could be a Domain Controller.

Port 389: LDAP

LDAP exposes directory-service functionality. AD directory contains things like: Users, Groups, Computers, OUs, Attributes, Group memberships

LDAP does not = vulnerable, but it may expose useful directory information depending on authentication and configuration.

Port 445: SMB

Is SMB reachable?

What versions/features are in use?

Does the server reveal shares?

Do anonymous queries work?

What access does an authenticated user have?

Is signing required?

Ports 3268 / 3269: Global Catalog

The Global Catalog allows forest-wide directory searches.

3268: Global Catalog LDAP

3269: Global Catalog LDAP protected with TLS

Port 5985: WinRM

Windows Remote Management over HTTP. WinRM is used for remote Windows management.

A remote-management service expands what an authorized administrator can do, and therefore also becomes something an assessor wants to understand. Exposed DNE vulnerable.

Port 9389: AD Web Services

This supports tools/components that interact with Active Directory, including modern AD management functionality.

Service Enumeration Theory

Yesterday: Host Discovery -> Port Enumeration -> Service Detection, but today I want to introduce Service-Specific Enumeration.

We don't want to treat every service like it's just a port number being open; we want to start asking questions which are specific to that protocol.

For SMB:

- What shares exist?
- What SMB capabilities exist?
- Can unauthenticated users learn anything?
- What does a normal domain account see?

For LDAP:

- Is LDAP reachable?
- Does it require authentication?
- What directory information can an authorized domain user query?

For DNS:

- What names/services does DNS know?
- Can I resolve domain infrastructure?
- What SRV records reveal AD services?

Practical: SMB Enumeration

Authorized Target: SRV-DC01

Let's verify SMB is still reachable: **nmap -Pn -p 445 192.168.1.236**

```
(nigist@kali)-[~]
$ nmap -Pn -p 445 192.168.1.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-19 10:10 EDT
Nmap scan report for 192.168.1.236
Host is up (0.0025s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.05 seconds
```

Learn smbclient

Kali includes tools that can “speak SMB.” One class is: smbclient. Going to look at its help: smbclient - -help. So, Nmap told us: SMB appears to exist. Smbclient can now actually interact with the SMB service.

List shares

To ask the server for available shares: **smbclient -L //<SERVER>**

-L means list available shares.

```
(nigist@kali)-[~]
$ smbclient -L //192.168.1.236
Password for [WORKGROUP\nigist]:
Anonymous login successful

      Sharename      Type      Comment
      -----      ----      -----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.1.236 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

So the anonymous access worked for this command...but the server is not disclosing the share information without authentication. This command will fail if SMB1 is disabled.